TRƯỜNG ĐẠI HỌC .....
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỒ ÁN MÔN HỌC

OSG203 — Hệ điều hành Linux

LINUXADMIN TOOLKIT

Bộ công cụ quản trị, giám sát và bảo vệ máy chủ Linux bằng Bash

---

Đề tài 3: *Bash Scripting cho System Administration*

Triển khai thực tế cho doanh nghiệp giả định TechNova Solutions

Giảng viên hướng dẫn: .....

Lớp: .....

Sinh viên thực hiện: Nguyễn Văn A — MSSV .....

Trần Thị B — MSSV .....

Lê Văn C — MSSV .....

TP. Hồ Chí Minh, tháng ..../2026

Tóm tắt

Báo cáo trình bày quá trình phân tích, thiết kế, hiện thực, **triển khai thực tế** và kiểm thử **LinuxAdmin Toolkit** — bộ công cụ quản trị máy chủ Linux viết hoàn toàn bằng Bash. Kịch bản sử dụng là công ty **TechNova Solutions** có một máy chủ Ubuntu tập trung (`technova-core-srv`); nhân viên SSH vào làm việc, còn Tech Lead làm việc từ xa và chỉ điều hành máy chủ qua SSH.

Toolkit gom công việc hằng ngày của Tech Lead vào **5 chức năng chính**:

1. **users** — quản lý vòng đời nhân viên và phân quyền theo phòng ban;
2. **monitor** — giám sát tài nguyên, hoạt động nhân viên và kiểm tra nhật ký hệ thống;
3. **alert** — cảnh báo sự cố và **phát hiện xâm nhập** (IDS dựa trên luật), gửi về Telegram và email;
4. **backup** — sao lưu có kiểm tra toàn vẹn, đẩy bản sao lên **Google Drive**;
5. **scheduler** — tự động hoá bằng cron hoặc **systemd timer**.

Khác với một bản demo trong máy ảo hay container, toolkit được **cài trực tiếp lên một máy Ubuntu thật** bằng một lệnh (`install.sh --server`) và để tự vận hành nhiều ngày. Máy khác trong mạng SSH vào để quản trị, đóng vai nhân viên, và thử tấn công dò mật khẩu; cảnh báo tới điện thoại qua Telegram, bản sao lưu nằm trên Google Drive.

Sản phẩm gồm khoảng **4.370 dòng Bash** với **71 action**, có hai chế độ dùng chuyển qua lại được (giao diện menu trong terminal và dòng lệnh). Bộ kiểm thử tự động đạt **75/75 PASS**; mã nguồn qua **shellcheck** không còn cảnh báo.

Từ khoá: Bash scripting, system administration, systemd, cron, sao lưu, Google Drive, giám sát, IDS, Telegram, SSH.

Mục lục

Tóm tắt **1**

1 Giới thiệu **5**
1.1 Bối cảnh doanh nghiệp . . . 5
1.2 Nhân vật chính và bài toán . . . 5
1.3 Ứng dụng thực tế . . . 5
1.4 Mục tiêu và phạm vi . . . 6
1.5 Liên hệ với các đề tài của môn học . . . 6
1.6 Cấu trúc báo cáo . . . 7

2 Cơ sở lý thuyết **8**
2.1 Bash scripting . . . 8
2.1.1 Cấu trúc một script chuẩn . . . 8
2.1.2 Các kỹ thuật được sử dụng . . . 9
2.2 Người dùng, nhóm và quyền truy cập . . . 9
2.3 Tiến trình, tín hiệu và lập lịch CPU . . . 10
2.4 Quá trình khởi động và systemd . . . 10
2.5 Lập lịch tác vụ: cron và at . . . 10
2.6 Sao lưu và lưu trữ đám mây . . . 10
2.7 Nhật ký hệ thống . . . 11
2.8 Giám sát tài nguyên . . . 11
2.9 Mạng, SSH và tường lửa . . . 11
2.10 Hệ thống phát hiện xâm nhập (IDS) . . . 12
2.10.1 Khái niệm . . . 12
2.10.2 Kiểm tra toàn vẹn tệp . . . 12
2.10.3 Vị trí của IDS trong toolkit . . . 12
2.11 Kênh cảnh báo . . . 13
2.12 Giao diện menu trong terminal . . . 13

3 Phân tích và thiết kế **14**
3.1 Yêu cầu chức năng . . . 14
3.2 Yêu cầu phi chức năng . . . 14
3.3 Kiến trúc tổng thể . . . 15
3.4 Cơ chế “registry”: khai báo chức năng một lần . . . 15
3.5 Chế độ chạy thử (dry-run) . . . 16

3.6 Thiết kế bộ phát hiện xâm nhập . . . 16
3.7 Mô hình triển khai thực tế . . . 18
3.8 Tổ chức mã nguồn . . . 18

4 Hiện thực **19**
4.1 Giao diện và chế độ làm việc . . . 19
4.2 Chức năng 1 — users: quản lý nhân viên và phân quyền . . . 19
4.3 Chức năng 2 — monitor: giám sát tài nguyên, nhân viên và nhật ký . . . 20
4.4 Chức năng 3 — alert: cảnh báo sự cố và phát hiện xâm nhập . . . 21
4.4.1 Cảnh báo sự cố . . . 21
4.4.2 Phát hiện xâm nhập: đếm lần đăng nhập thất bại . . . 22
4.4.3 Danh sách tin cậy theo dải mạng . . . 22
4.4.4 Cảnh báo và chặn IP . . . 23
4.5 Chức năng 4 — backup: sao lưu tài sản số . . . 23
4.6 Chức năng 5 — scheduler: tự động hoá bảo dưỡng . . . 24
4.7 Triển khai một lệnh: `install.sh --server` . . . 25

5 Triển khai thực tế và workflow demo **27**
5.1 Môi trường triển khai . . . 27
5.2 Quy trình triển khai . . . 27
5.3 Workflow demo . . . 28
5.3.1 Bước 1 — Mở đầu: đây là máy chủ thật . . . 28
5.3.2 Bước 2 — users: nhân viên làm việc và phân quyền . . . 29
5.3.3 Bước 3 — monitor: có người treo process . . . 29
5.3.4 Bước 4 — alert: cảnh báo tới điện thoại . . . 29
5.3.5 Bước 5 — backup: sao lưu lên Google Drive . . . 29
5.3.6 Bước 6 — scheduler và systemd: máy chủ tự vận hành . . . 30
5.3.7 Bước 7 — nhân viên nghỉ việc, rồi máy chủ bị tấn công . . . 30
5.3.8 Bước 8 — kết quả vận hành thực tế . . . 32

6 Kiểm thử và đánh giá **34**
6.1 Môi trường kiểm thử . . . 34
6.2 Kịch bản kiểm thử tự động . . . 34
6.3 Kết quả vận hành thực tế . . . 36
6.4 Đánh giá lợi ích của tự động hoá . . . 36
6.5 Hạn chế . . . 36

7 Kết luận và hướng phát triển **38**
7.1 Kết luận . . . 38
7.2 Hướng phát triển . . . 38

A Hướng dẫn sử dụng **39**
A.1 Cài đặt trên máy Ubuntu thật 39
A.2 Các lệnh thường dùng 40
A.3 Tham số cấu hình chính 40

B Danh sách lệnh **42**

Danh sách hình vẽ

3.1 Kiến trúc LinuxAdmin Toolkit 15
3.2 Luồng xử lý của `alert security` 16
3.3 Bố trí triển khai và demo trên máy chủ thật 18

4.1 Menu chính của giao diện TUI khi SSH vào máy chủ 19
4.2 Danh sách nhân viên theo phòng ban 19
4.3 Nhân viên phòng data không xem được thư mục phòng dev; file mới kế thừa nhóm nhờ SGID 20
4.4 Kiểm tra an ninh tài khoản 20
4.5 Nhân viên đang đăng nhập từ máy khác 21
4.6 Phát hiện tiến trình `train_model.py` của cuonglv chiếm CPU 21
4.7 alert check phát hiện tiến trình ngốn tài nguyên 22
4.8 Tin cảnh báo trên điện thoại (Telegram) 22
4.9 IDS phát hiện dò mật khẩu, dò tên tài khoản, đăng nhập sau khi dò và tự chặn IP 23
4.10 Tin [TẤN CÔNG] trên điện thoại 23
4.11 Sao lưu, kiểm tra toàn vẹn và tải lên Google Drive 24
4.12 Các bản sao lưu của nhiều đêm trên Google Drive 24
4.13 Bốn systemd timer của toolkit đã chạy nhiều lần 25
4.14 Triển khai toolkit lên máy Ubuntu thật bằng một lệnh 26

5.1 Các mốc triển khai 27
5.2 Tin thử từ toolkit tới Telegram 28
5.3 Kết nối Google Drive 28
5.4 Thứ tự các phần trong buổi demo 28
5.5 Quản trị máy chủ từ máy khác qua SSH 29
5.6 Tin “ĐÃ ỔN ĐỊNH” sau khi xử lý sự cố 29
5.7 Kiểm tra toàn vẹn và khôi phục đúng nội dung 30
5.8 Service do toolkit tạo 30
5.9 Nhật ký các đêm sao lưu trong journald 30
5.10 Quy trình nghỉ việc 5 bước 31
5.11 Phiên của nhân viên nghỉ việc bị ngắt và không vào lại được 31
5.12 Laptop 2 thử đăng nhập bằng nhiều tài khoản với mật khẩu sai 31
5.13 Kết nối từ Laptop 2 bị tường lửa chặn 32
5.14 Danh sách IP bị chặn và luật iptables tương ứng 32
5.15 Báo cáo nhật ký 1 giờ qua 32

5.16 Lịch sử cảnh báo trong thời gian vận hành 33
5.17 Báo cáo HTML với biểu đồ CPU/RAM/Disk nhiều ngày 33
5.18 Các gói log hằng đêm trên Google Drive 33

6.1 Kết quả chạy bộ kiểm thử tự động 35

Danh sách bảng

1.1 Rủi ro thực tế và cách toolkit xử lý 6
1.2 Các đề tài của môn học được thể hiện trong toolkit 7

2.1 Kỹ thuật Bash và vị trí sử dụng trong toolkit 9
2.2 Phân loại IDS 12

3.1 Ánh xạ nhu cầu của Tech Lead sang 5 chức năng 14
3.2 9 luật phát hiện của IDS 17

4.1 Lịch tự động mặc định 25
4.2 Các câu hỏi của `install.sh --server` 26

5.1 Thiết bị triển khai 27

6.1 Kết quả kiểm thử tự động 35
6.2 Số liệu sau thời gian máy chủ tự vận hành 36
6.3 So sánh thao tác thủ công và dùng toolkit (ước tính của nhóm) 36

A.1 Tra cứu nhanh theo tình huống 40
A.2 Tham số cấu hình chính 41

CHƯƠNG 1

Giới thiệu

1.1 Bối cảnh doanh nghiệp

TechNova Solutions là công ty công nghệ chuyên phát triển phần mềm và phân tích dữ liệu. Hạ tầng xoay quanh một **máy chủ Ubuntu tập trung** tên `technova-core-srv`. Toàn bộ nhân sự SSH vào máy chủ này để làm việc:

- **Lập trình viên** (nhóm `dev`) viết và commit code;
- **Data Analyst** (nhóm `data`) chạy tác vụ huấn luyện mô hình;
- **Tester** (nhóm `qa`) chạy kiểm thử.

1.2 Nhân vật chính và bài toán

Anh Hưng là Tech Lead kiêm quản trị hệ thống. Anh làm việc từ xa và **chỉ dùng terminal qua SSH**. Công việc hằng ngày gồm:

1. cấp quyền và quản lý nhân viên: tài khoản, phòng ban, thư mục dự án, sudo, thủ tục nghỉ việc;
2. giám sát máy chủ: ai đang đăng nhập và làm gì, có ai treo process ngốn CPU/RAM;
3. nhận cảnh báo tức thời khi có sự cố hoặc **khi máy chủ bị tấn công**, bất kể ngày đêm;
4. tự động hoá bảo dưỡng, sao lưu an toàn và **lưu bản sao ra ngoài máy chủ**.

Làm tay, mỗi việc gồm hàng chục lệnh rời rạc, dễ sai và khó lặp lại. Bài toán là **tự động hoá toàn bộ bằng Bash script**.

1.3 Ứng dụng thực tế

Đối tượng sử dụng là doanh nghiệp nhỏ và startup có vài máy chủ Linux nhưng không có đội IT riêng, không đủ ngân sách hoặc nhân lực để vận hành các nền tảng chuyên dụng như Zabbix, Wazuh hay Veeam. Toolkit giải quyết đúng các rủi ro thường gặp ở những nơi này:

Bảng 1.1: Rủi ro thực tế và cách toolkit xử lý

Rủi ro thật	Toolkit xử lý
Nhân viên nghỉ việc vẫn còn SSH, sudo, crontab	`users offboard`: khoá và thu hồi đủ 5 bước
Máy chủ có IP public bị bot dò mật khẩu SSH liên tục	IDS phát hiện, tự chặn IP bằng tường lửa, báo về Telegram
Ổ đầy hoặc process treo lúc 2 giờ sáng	Kiểm tra mỗi 5 phút, báo lên điện thoại
Ransomware, hỏng ổ cứng làm mất dữ liệu	Sao lưu có checksum, bản sao nằm ngoài máy (Google Drive)
Sau sự cố không biết chuyện gì đã xảy ra	`monitor logcheck`; log được lưu lên Drive mỗi đêm

Toolkit chỉ cần Bash và các lệnh có sẵn của Linux, cài trong một lệnh, giao diện tiếng Việt và dùng hoàn toàn qua SSH.

1.4 Mục tiêu và phạm vi

- Bộ công cụ **viết hoàn toàn bằng Bash**, chạy trên Ubuntu/Debian và tương thích RHEL/Rocky.
- Đủ **5 chức năng chính** theo nhu cầu của Tech Lead; dùng được qua SSH với hai chế độ TUI và CLI.
- **An toàn**: thao tác thay đổi hệ thống phải xác nhận và có chế độ chạy thử (*dry-run*).
- **Triển khai thật**: cài lên máy Ubuntu thật, vận hành liên tục, quản trị từ máy khác.

Ngoài phạm vi: quản lý tập trung nhiều máy chủ, giao diện web, phát hiện xâm nhập bằng học máy.

1.5 Liên hệ với các đề tài của môn học

Đề tài chính là **đề tài 3**, nhưng toolkit đồng thời thực hành nội dung của nhiều đề tài khác:

Bảng 1.2: Các đề tài của môn học được thể hiện trong toolkit

Đề tài	Thể hiện trong toolkit
3. Bash scripting cho SysAdmin	Toàn bộ toolkit: backup tự động, tạo user hàng loạt, monitor disk, đánh giá lợi ích automation
1. Process management	`monitor top/hogs/renice/kill`: `ps`, `nice`, tín hiệu, CFS
4. Boot process & systemd	4 cặp service + timer do toolkit tạo; journald
5. User & security	`users`: `/etc/passwd`, `/etc/shadow`, sudo, `chmod/chown`, chính sách mật khẩu
6. Network & remote admin	Quản trị qua SSH từ máy khác; tường lửa iptables/ufw chặn IP tấn công
9. Monitoring & troubleshooting	`monitor`, `logcheck`: `top`, `free`, `df`, rsyslog, journald, quy trình chẩn đoán
10. Cron & shell automation	`scheduler`: cron, at, cảnh báo email

1.6 Cấu trúc báo cáo

Chương 2 trình bày cơ sở lý thuyết; chương 3 phân tích và thiết kế; chương 4 hiện thực từng chức năng; chương 5 mô tả triển khai thực tế và workflow demo; chương 6 kiểm thử và đánh giá; chương 7 kết luận. Phụ lục gồm hướng dẫn sử dụng và danh sách lệnh.

CHƯƠNG 2

Cơ sở lý thuyết

2.1 Bash scripting

Bash (Bourne Again SHell) là shell mặc định của hầu hết bản phân phối Linux. Bash script là tệp văn bản chứa các lệnh shell được thực thi tuần tự, có đủ cấu trúc của một ngôn ngữ lập trình: biến, điều kiện, vòng lặp, hàm và mảng.

2.1.1 Cấu trúc một script chuẩn

```
#!/usr/bin/env bash          # shebang: chọn trình thông dịch
set -Eeuo pipefail           # chế độ "nghiêm ngặt"
trap 'on_error $LINENO' ERR  # bắt lỗi, báo số dòng
trap 'cleanup' EXIT          # dọn file tạm khi thoát
main() { ... }               # chương trình chính trong hàm
main "$@"
```

- `-e`: dừng ngay khi một lệnh lỗi; `-u`: báo lỗi khi dùng biến chưa khai báo;
- `-o pipefail`: pipeline lỗi nếu bất kỳ lệnh nào trong đó lỗi;
- `-E`: bẫy `ERR` có hiệu lực cả trong hàm và subshell.

2.1.2 Các kỹ thuật được sử dụng

Bảng 2.1: Kỹ thuật Bash và vị trí sử dụng trong toolkit

Kỹ thuật	Ứng dụng trong toolkit
Hàm, biến `local`, mã thoát	Mỗi chức năng là một hàm `<module>_<action>`
`getopts` + tuỳ chọn dài	`--tui`, `--cli`, `--dry-run`, `--yes`
Mảng kết hợp (`declare -A`)	"Registry" lưu module, action, tham số
Mở rộng tham số	`${var:-mặc định}`, `${var//a/b}`, `${var%%.*}`
Biểu thức chính quy `[[ =~ ]]`, `sed -E`	Kiểm tra username, PID, cron; tách IP/user khỏi log SSH
Số học bit `$(( a << 24 ))`	So khớp IP với dải mạng CIDR (whitelist)
`< <(...)`, `mapfile`, here-doc	Đọc CSV nhân viên, crontab, danh sách tiến trình
`awk`	Tổng hợp CPU/RAM theo người dùng, đếm lần đăng nhập thất bại theo IP
`trap ERR/EXIT/INT`	Báo lỗi, dọn file tạm, xử lý Ctrl+C
`flock`, `timeout`	Chống sao lưu chạy trùng; không treo khi gửi mail
`curl`, `sha256sum`, `logger`	Gọi Telegram Bot API; kiểm tra toàn vẹn; ghi journald

2.2 Người dùng, nhóm và quyền truy cập

Thông tin tài khoản lưu trong `/etc/passwd` (tên, UID, GID, home, shell), `/etc/shadow` (mật khẩu đã băm và chính sách hết hạn, chỉ root đọc được) và `/etc/group`. Mỗi tệp có quyền **rwx** cho chủ sở hữu, nhóm và người khác, biểu diễn bát phân với $r = 4$, $w = 2$, $x = 1$. Ba bit đặc biệt:

- **SUID** (4): chương trình chạy với quyền của chủ sở hữu tệp;
- **SGID** (2): trên thư mục, tệp mới tạo *kế thừa nhóm* của thư mục — dùng cho thư mục phòng ban (`2770`);
- **Sticky bit** (1): trong thư mục ai cũng ghi được, mỗi người chỉ xoá được tệp của mình — dùng cho thư mục chung (`1777`).

Quyền quản trị cấp qua nhóm `sudo` (Debian/Ubuntu) hoặc `wheel` (RHEL). Chính sách mật khẩu điều khiển bằng `/etc/login.defs` và lệnh `chage`. Tài khoản có **UID 0** có toàn quyền root, nên một tài khoản UID 0 lạ là dấu hiệu bị cài cửa hậu.

2.3 Tiến trình, tín hiệu và lập lịch CPU

Mỗi tiến trình có PID và tiến trình cha (PPID); kernel cung cấp thông tin qua hệ thống tệp ảo `/proc/<pid>/`. Bộ lập lịch mặc định của Linux là **CFS** (Completely Fair Scheduler, từ kernel 6.6 là EEVDF): chia thời gian CPU theo trọng số suy ra từ giá trị **nice** (-20 ưu tiên cao nhất đến 19 thấp nhất). Công cụ: `ps`, `top`, `w`, `last`, `nice`/`renice`, `kill`. Hai tín hiệu hay dùng là **SIGTERM** (15) — yêu cầu kết thúc lịch sự — và **SIGKILL** (9) — buộc dừng ngay.

2.4 Quá trình khởi động và systemd

Máy Linux khởi động theo chuỗi: **BIOS/UEFI** $\rightarrow$ **bootloader** (GRUB) $\rightarrow$ **kernel** $\rightarrow$ tiến trình đầu tiên PID 1 là **systemd**. systemd quản lý mọi thành phần dưới dạng **unit**:

- **service** (`.service`): một dịch vụ hoặc tác vụ; `Type=oneshot` cho tác vụ chạy xong rồi thoát;
- **timer** (`.timer`): kích hoạt service theo lịch (`OnCalendar=`) hoặc theo chu kỳ (`OnUnitActiveSec=`); `Persistent=true` chạy bù nếu máy tắt đúng giờ hẹn;
- **socket**, **target**, **mount**…

Unit do quản trị viên tạo đặt trong `/etc/systemd/system/`, nạp bằng `systemctl daemon-reload` và bật bằng `systemctl enable --now`. Mọi đầu ra của service được **journald** thu thập, xem bằng `journalctl -u <unit>`.

2.5 Lập lịch tác vụ: cron và at

cron chạy tác vụ định kỳ theo biểu thức 5 trường *phút giờ ngày tháng thứ*; ví dụ `30 3 * * *` là 03:30 mỗi ngày, `*/5 * * * *` là mỗi 5 phút. **at** hẹn chạy một lần (`at now + 2 minutes`). So với cron, systemd timer có log tập trung trong journald, chạy bù khi máy tắt, và kiểm soát tài nguyên (`Nice=`, `IOSchedulingClass=idle`).

2.6 Sao lưu và lưu trữ đám mây

Toolkit áp dụng các nguyên tắc:

- nén bằng `tar`, giữ nguyên quyền và chủ sở hữu;
- **checksum SHA-256** để phát hiện bản sao bị hỏng hoặc bị sửa;
- **xoay vòng**: chỉ giữ N bản mới nhất;
- **quy tắc 3-2-1**: 3 bản dữ liệu, trên 2 loại lưu trữ, 1 bản ở nơi khác. Toolkit đẩy bản sao lên **Google Drive**, nên dù máy chủ hỏng hoặc bị mã hoá tống tiền, bản sao vẫn còn.

Việc tải lên dùng **rclone**, xác thực bằng **OAuth 2.0**: người dùng đăng nhập Google trên máy có trình duyệt (`rclone authorize "drive"`), nhận token rồi dán vào máy chủ. Toolkit chỉ xin quyền `drive.file` — chỉ đọc/ghi được tệp do chính nó tạo, không thấy tài liệu khác trong Drive.

2.7 Nhật ký hệ thống

journald thu thập log của kernel và mọi service; **rsyslog** có thể ghi lại thành tệp văn bản trong `/var/log` (`auth.log` cho xác thực, `syslog`, `kern.log`). Mỗi bản ghi syslog có **facility** (nguồn: `auth`=4, `authpriv`=10, `kern`=0…) và **mức độ** (`err`, `warning`…). SSH server ghi các dòng như:

```
sshd[812]: Failed password for invalid user admin from 203.0.113.9 port 51622 ssh2
sshd[812]: Invalid user oracle from 203.0.113.9 port 51630
sshd-session[930]: Connection closed by authenticating user root 198.51.100.5 port 6011 [preau
sshd[955]: Accepted publickey for hungnv from 192.168.1.20 port 50311 ssh2
```

Khi máy chủ **chỉ cho đăng nhập bằng SSH key**, bot dò mật khẩu không tạo dòng `Failed password` mà chỉ để lại `Invalid user` và `[preauth]`. Đây là chi tiết quan trọng khi thiết kế bộ phát hiện tấn công.

2.8 Giám sát tài nguyên

Các chỉ số đọc trực tiếp từ kernel: CPU từ `/proc/stat` (hiệu số giữa hai lần lấy mẫu), bộ nhớ từ `/proc/meminfo` (*MemAvailable*), tải từ `/proc/loadavg`, dung lượng đĩa bằng `df`, cổng đang mở bằng `ss -tuln`.

2.9 Mạng, SSH và tường lửa

SSH (cổng 22) là kênh quản trị từ xa được mã hoá. Cấu hình máy chủ nằm ở `/etc/ssh/sshd_config` và thư mục `sshd_config.d/`; hai tham số bảo mật quan trọng là `PermitRootLogin no` và `MaxAuthTries`. Tường lửa của Linux là **netfilter**, điều khiển bằng `iptables`/`nftables` hoặc giao diện đơn giản `ufw`. Chặn một IP:

```
iptables -I INPUT -s 203.0.113.9 -j DROP -m comment --comment "sysadmin-toolkit IDS"
```

Khi quản trị qua Internet mà không có IP public, có thể dùng VPN dạng lưới như **Tailscale** (mỗi máy nhận IP `100.x.x.x`). Không nên dùng tunnel kiểu ngrok cho SSH, vì máy chủ thấy mọi kết nối đến từ `127.0.0.1` và không biết IP thật của kẻ tấn công.

2.10 Hệ thống phát hiện xâm nhập (IDS)

2.10.1 Khái niệm

IDS (Intrusion Detection System) là hệ thống theo dõi hoạt động của máy tính hoặc mạng để phát hiện dấu hiệu tấn công hoặc vi phạm chính sách, rồi cảnh báo cho quản trị viên. IDS được gọi tên theo *mục đích*, không theo kỹ thuật bên trong. Có thể phân loại theo hai tiêu chí:

Bảng 2.2: Phân loại IDS

Tiêu chí	Loại	Ví dụ
Vị trí theo dõi	**NIDS**: soi gói tin trên mạng	Snort, Suricata, Zeek
	HIDS: theo dõi chính máy chủ (log, tệp, tiến trình)	OSSEC, Wazuh, AIDE, fail2ban
Cách phát hiện	**Dựa trên luật / chữ ký**: so với mẫu tấn công đã biết, kèm ngưỡng	Luật Snort, regex fail2ban
	Dựa trên bất thường: học trạng thái "bình thường", báo khi lệch xa (thống kê, học máy)	Chủ yếu trong nghiên cứu; một số sản phẩm thương mại

Phần lớn IDS dùng trong doanh nghiệp là **dựa trên luật**, vì dễ giải thích, ít báo nhầm và chạy nhẹ. Ví dụ một luật Snort phát hiện dò mật khẩu SSH — về bản chất là một điều kiện "nếu… thì báo động":

```
alert tcp any any -> $HOME_NET 22 (msg:"SSH brute force";
      detection_filter:track by_src, count 5, seconds 60; sid:1000001;)
```

2.10.2 Kiểm tra toàn vẹn tệp

Một nhánh khác của HIDS là **kiểm tra toàn vẹn** (AIDE, Tripwire): chụp checksum các tệp quan trọng lúc hệ thống còn sạch (*baseline*), định kỳ so sánh lại. Tệp `/etc/passwd` hay `sshd_config` bị sửa ngoài ý muốn là dấu hiệu kẻ xâm nhập đang cài cửa hậu.

2.10.3 Vị trí của IDS trong toolkit

IDS của toolkit là một **HIDS dựa trên luật** kết hợp **kiểm tra toàn vẹn**: nó gộp ý tưởng của fail2ban (đọc log, chặn IP) và AIDE (so checksum), viết hoàn toàn bằng Bash. Toolkit **không dùng học máy**; hướng phát hiện bất thường bằng thống kê được nêu ở phần hướng phát triển.

2.11 Kênh cảnh báo

- **Email**: gửi qua SMTP bằng `msmtp` (ví dụ Gmail với Mật khẩu ứng dụng). Tiêu đề tiếng Việt mã hoá theo RFC 2047 (`=?UTF-8?B?...?=`).
- **Telegram Bot API**: gọi HTTPS `POST https://api.telegram.org/bot<TOKEN>/sendMessage` bằng `curl` với `chat_id` và nội dung — tin tới điện thoại gần như tức thời.

2.12 Giao diện menu trong terminal

`dialog` và `whiptail` vẽ hộp thoại ngay trong terminal bằng ncurses/newt, nên hoạt động tốt qua SSH mà không cần môi trường đồ hoạ.

CHƯƠNG 3

Phân tích và thiết kế

3.1 Yêu cầu chức năng

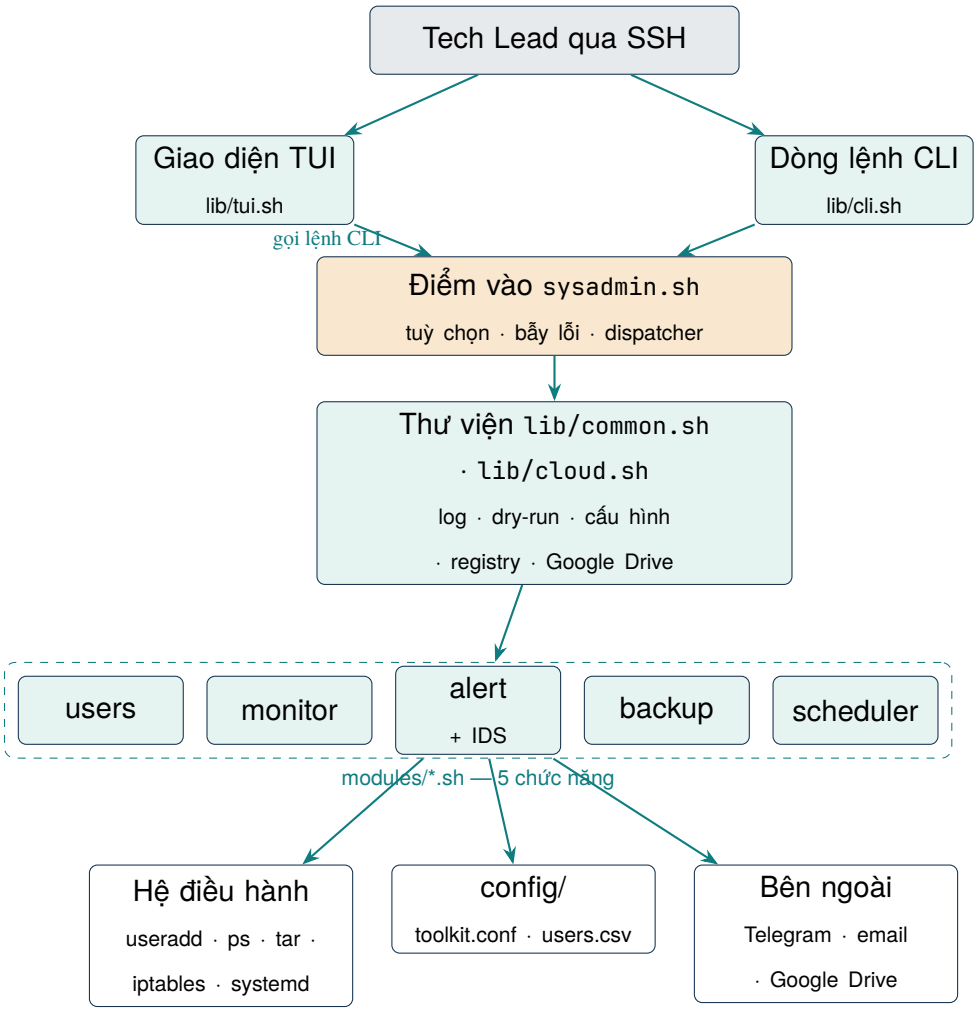
Bảng 3.1: Ánh xạ nhu cầu của Tech Lead sang 5 chức năng

#	Nhu cầu	Chức năng	Các action chính
1	Cấp quyền, quản lý nhân viên	`users`	create, setup-dirs, sudo, lock/unlock, kick, **offboard**, audit
2	Ai đang làm gì, ai treo process, log có gì lạ	`monitor`	**who**, **usage**, **hogs**, renice, kill, troubleshoot, **logcheck**, **log-upload**, report
3	Cảnh báo sự cố và tấn công ngày đêm	`alert`	**check**, **security**, baseline, **ban**/unban/banned, setup-telegram, setup-mail, test
4	Sao lưu an toàn, có bản ngoài máy	`backup`	**run**, verify, restore, rotate, **cloud-setup**, cloud-list
5	Tự động hoá bảo dưỡng	`scheduler`	install, **timers-install**, maintenance, explain, at

3.2 Yêu cầu phi chức năng

- **Vận hành từ xa**: mọi chức năng dùng được qua SSH, không cần đồ hoạ.
- **An toàn**: thao tác thay đổi hệ thống phải xác nhận, có dry-run; từ chối thao tác lên tài khoản hệ thống (UID < 1000) và PID 1; không bao giờ chặn IP trong danh sách tin cậy.
- **Không spam**: mỗi loại cảnh báo chỉ gửi lại sau một khoảng chờ (mặc định 30 phút).
- **Lặp lại được**: chạy lại một lệnh không gây trùng lặp.
- **Truy vết**: mọi lệnh thay đổi hệ thống ghi log ra tệp và journald.

3.3 Kiến trúc tổng thể



Hình 3.1: Kiến trúc LinuxAdmin Toolkit

Điểm mấu chốt: **giao diện chỉ là lớp vỏ**. Khi chọn một chức năng trên menu, toolkit hỏi tham số qua hộp thoại rồi gọi lại chính nó dưới dạng lệnh CLI, ví dụ `sysadmin monitor hogs 90 30`. Hai chế độ vì vậy luôn cho kết quả giống hệt nhau.

3.4 Cơ chế "registry": khai báo chức năng một lần

Mỗi module tự khai báo action kèm cờ và tham số; trang trợ giúp, menu CLI và menu TUI đều được **sinh tự động**:

```
register_module alert 3 "Cảnh báo sự cố & phát hiện tấn công"
register_action security "r"  "Phát hiện tấn công bất thường (IDS)"
register_action ban      "rd" "Chặn một IP bằng tường lửa" "Địa chỉ IP"
```

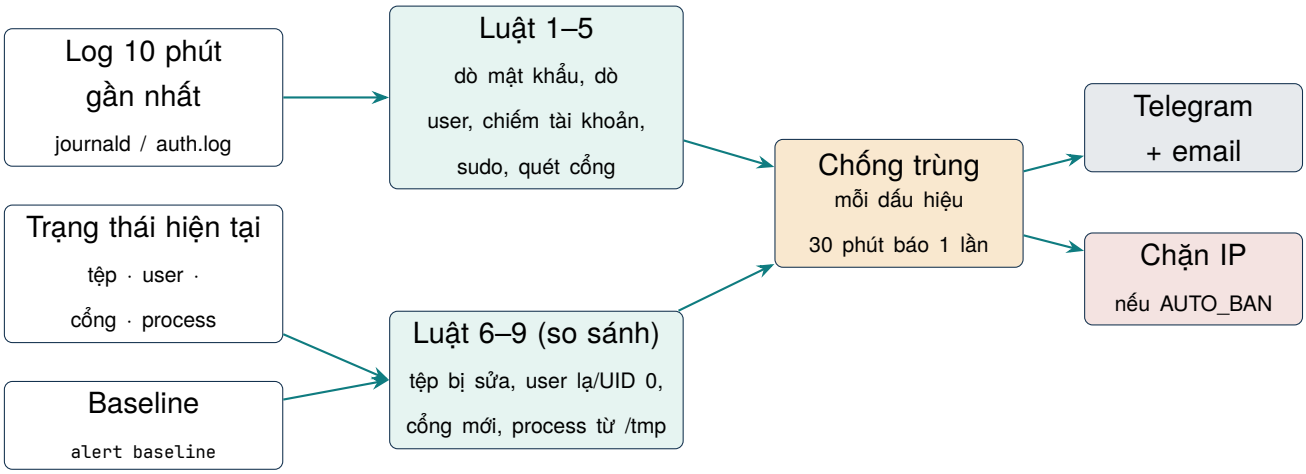
Cờ `r`: cần root; cờ `d`: thay đổi hệ thống, phải xác nhận. Tham số dạng `"Lời nhắc=mặc định"`, `a|b|c` (chọn một) hoặc `@hàm` (danh sách động). Hàm thực thi tương ứng là `alert_security`, `alert_ban`.

3.5 Chế độ chạy thử (dry-run)

Mọi lệnh thay đổi hệ thống được bọc qua hàm `run`: ở chế độ `--dry-run` chỉ in lệnh, ở chế độ thường ghi log rồi chạy và báo lỗi rõ ràng:

```
run() {
  if [[ $DRY_RUN == 1 ]]; then
    printf '[DRY-RUN] %s\n' "$(shell_quote "$@")"; return 0
  fi
  _log_write CMD "$(shell_quote "$@")"
  "$@" && return 0
  local rc=$?
  log_error "Lệnh thất bại (mã $rc): $(shell_quote "$@")"; return "$rc"
}
```

3.6 Thiết kế bộ phát hiện xâm nhập



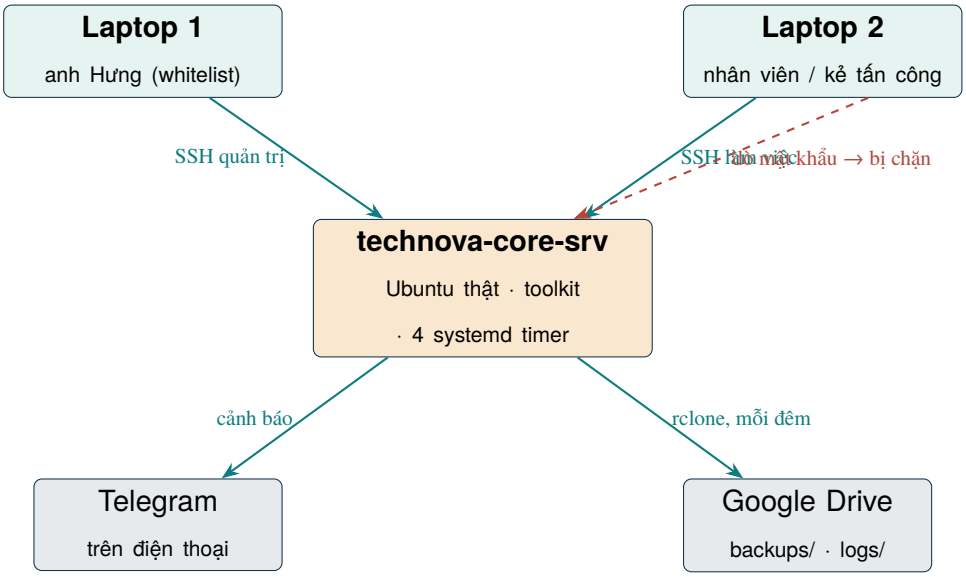
Hình 3.2: Luồng xử lý của `alert security`

Bảng 3.2: 9 luật phát hiện của IDS

#	Dấu hiệu	Ý nghĩa	Mức
1	≥ 5 lần đăng nhập SSH thất bại từ cùng một IP	Dò mật khẩu (brute-force)	WARN
2	≥ 5 username không tồn tại bị thử	Dò tên tài khoản (password spraying)	WARN
3	IP vừa dò mật khẩu **đăng nhập thành công**	Có thể đã bị chiếm tài khoản	FAIL
4	sudo sai nhiều lần; user ngoài sudoers dùng sudo	Cố leo thang đặc quyền	WARN/FAIL
5	Tường lửa chặn ≥ 20 gói từ một IP	Quét cổng	WARN
6	Checksum `passwd`, `shadow`, `sudoers`, `sshd_config`… thay đổi	Sửa cấu hình hệ thống	FAIL
7	Tài khoản mới không tạo qua toolkit; tài khoản UID 0	Cài tài khoản cửa hậu	FAIL
8	Cổng mạng mới đang lắng nghe	Chương trình cửa hậu chờ kết nối	WARN
9	Tiến trình chạy từ `/tmp`, `/var/tmp`, `/dev/shm`	Mã độc (ví dụ đào coin)	FAIL

Để không báo nhầm khi chính quản trị viên thay đổi hệ thống: tạo user bằng toolkit thì baseline tự cập nhật; sửa cấu hình bằng tay thì chạy `alert baseline`.

3.7 Mô hình triển khai thực tế



Hình 3.3: Bố trí triển khai và demo trên máy chủ thật

Máy chủ là **máy Ubuntu thật**, không phải container: toolkit quản trị chính máy đó (user, tiến trình, log, tường lửa, systemd). Container Docker chỉ dùng để chạy bộ kiểm thử tự động và làm phương án dự phòng, vì container chỉ thấy user/tiến trình/log bên trong nó và không có systemd.

3.8 Tổ chức mã nguồn

```
sysadmin-toolkit/
├── sysadmin.sh            điểm vào: getopts, chọn chế độ, trap
├── install.sh             cài vào /opt; --server: triển khai lên máy thật
├── lib/   common.sh · cli.sh · tui.sh · cloud.sh
├── modules/   users · monitor · alert · backup · scheduler
├── config/    toolkit.conf · users.csv
├── systemd/   toolkit-{monitor,backup,maintenance,report}.{service,timer}
├── tests/demo-test.sh     kiểm thử tự động 75 bước
└── Dockerfile · docker-compose.yml · package.sh
```

CHƯƠNG 4

Hiện thực

4.1 Giao diện và chế độ làm việc

Chạy `sysadmin` không tham số, toolkit cho chọn chế độ. Chế độ TUI hiển thị menu 5 chức năng; thanh tiêu đề cho biết người dùng, máy chủ và trạng thái dry-run. Với thao tác thay đổi hệ thống, giao diện cho chọn *Chạy thật / Chạy thử / Huỷ*.

CHÈN ẢNH: `hinh/06-tui-main.png`

Laptop 1: `ssh hungnv@<IP>` rồi `sudo sysadmin --tui`. Chụp menu 5 chức năng.

Hình 4.1: Menu chính của giao diện TUI khi SSH vào máy chủ

4.2 Chức năng 1 — users: quản lý nhân viên và phân quyền

Danh sách nhân viên khai báo trong `config/users.csv` (username, họ tên, phòng ban, shell, sudo). `users create` xử lý từng dòng: kiểm tra tên hợp lệ, bỏ qua nếu đã có, tạo nhóm phòng ban, `useradd`, đặt mật khẩu ngẫu nhiên qua `chpasswd`, ép đổi mật khẩu ở lần đăng nhập đầu và áp chính sách hết hạn (`chage -d 0 -M 90 -m 1 -W 7`). Mật khẩu tạm lưu trong tệp quyền `600`.

`users setup-dirs` tạo `/srv/technova/{dev,data,qa}` quyền `2770` (SGID) và thư mục `chung/` quyền `1777` (sticky).

CHÈN ẢNH: `hinh/07-users-list.png`

Laptop 1: `sudo sysadmin users list`.

Hình 4.2: Danh sách nhân viên theo phòng ban

CHÈN ẢNH: `hinh/08-phan-quyen.png`

Laptop 2 (đăng nhập `cuonglv`): `ls /srv/technova/dev` (bị Permission denied), rồi `echo "model v1" > /srv/technova/data/model.txt; ls -l /srv/technova/data`.

Hình 4.3: Nhân viên phòng data không xem được thư mục phòng dev; file mới kế thừa nhóm nhờ SGID

Khi nhân viên nghỉ việc, `users offboard` chạy liền 5 bước: khoá mật khẩu và đặt hết hạn (`usermod -L -e 1`, chặn cả SSH key); ngắt mọi phiên (`loginctl terminate-user`, `pkill -KILL -u`); thu hồi sudo; xoá crontab cá nhân; nén thư mục home để lưu trữ. `users audit` kiểm tra tài khoản UID 0, mật khẩu rỗng, quyền `/etc/shadow` và `sudoers`, quy tắc NOPASSWD, tệp SUID và cấu hình SSH.

CHÈN ẢNH: `hinh/09-users-audit.png`

Laptop 1: `sudo sysadmin users audit`. Chụp phần tổng kết.

Hình 4.4: Kiểm tra an ninh tài khoản

4.3 Chức năng 2 — monitor: giám sát tài nguyên, nhân viên và nhật ký

`monitor who` cho biết ai đang đăng nhập, từ IP nào, đang chạy lệnh gì. `monitor usage` cộng dồn CPU/RAM **theo từng nhân viên**:

```
ps -eo user:20=,uid=,pcpu=,pmem=,rss= | awk '
  { u=$1; p[u]++; c[u]+=$3; m[u]+=$4; r[u]+=$5 }
  END { for (u in p) printf "%.1f\t%s %d %.1f %.1f %.0f\n",
        c[u], u, p[u], c[u], m[u], r[u]/1024 }' | sort -rn
```

`monitor hogs` lọc tiến trình vượt ngưỡng ($\geq$ 90% CPU hoặc $\geq$ 30% RAM) và hiện dòng lệnh đầy đủ. Xử lý bằng `monitor renice` (hạ ưu tiên) hoặc `monitor kill` (có xác nhận, từ chối PID 1).

CHÈN ẢNH: `hinh/10-monitor-who.png`

Laptop 1: `sysadmin monitor who` khi Laptop 2 đang SSH bằng `cuonglv`. Thấy IP của Laptop 2.

Hình 4.5: Nhân viên đang đăng nhập từ máy khác

CHÈN ẢNH: `hinh/11-monitor-hogs.png`

Laptop 2 chạy tiến trình nặng (bước 4.1 trong kịch bản demo), Laptop 1: `sysadmin monitor usage` và `sysadmin monitor hogs`.

Hình 4.6: Phát hiện tiến trình `train_model.py` của cuonglv chiếm CPU

Kiểm tra nhật ký — `monitor logcheck [giờ]` đọc journald hoặc `/var/log` và tổng hợp 7 mục: đăng nhập SSH thất bại theo IP, tên user bị dò, đăng nhập thành công/bằng root, sudo/su, thay đổi tài khoản, dịch vụ lỗi, sự kiện kernel (hết RAM, segfault, lỗi đĩa), tường lửa chặn. `monitor log-upload` đóng gói báo cáo logcheck cùng `syslog`, `auth.log` và log của toolkit thành `.tar.gz` kèm SHA-256, rồi tải lên Google Drive.

Ngoài ra: `troubleshoot` (chẩn đoán 10 bước), `report` (báo cáo HTML có biểu đồ), `watch` (bảng theo dõi thời gian thực).

4.4 Chức năng 3 — alert: cảnh báo sự cố và phát hiện xâm nhập

4.4.1 Cảnh báo sự cố

`alert check` chạy mỗi 5 phút: đo CPU, RAM, ổ đĩa và ghi `metrics.csv`; phát hiện tiến trình ngốn tài nguyên kèm tên nhân viên; phát hiện dịch vụ systemd lỗi; gọi IDS; nếu có sự cố thì gửi **email** và **Telegram**. Có cooldown 30 phút; hết sự cố thì gửi tin "đã ổn định". Gửi mail được giới hạn thời gian (`timeout`) để không treo khi máy chủ SMTP không phản hồi.

CHÈN ẢNH: `hinh/12-alert-check.png`

Laptop 1: `sudo sysadmin alert check` khi tiến trình nặng còn chạy.

Hình 4.7: alert check phát hiện tiến trình ngốn tài nguyên

CHÈN ẢNH:
`hinh/13-telegram-canh-bao.png`

Chụp màn hình điện
thoại ngay sau bước trên.

Hình 4.8: Tin cảnh báo trên điện thoại (Telegram)

4.4.2 Phát hiện xâm nhập: đếm lần đăng nhập thất bại

Để bắt được dò mật khẩu cả khi máy chủ chỉ cho đăng nhập bằng key, toolkit chuẩn hoá mọi dòng log liên quan thành bộ *(loại, IP, cổng, user)*, rồi đếm **theo kết nối** (IP + cổng nguồn) để không đếm trùng các dòng của cùng một lần thử:

```
ssh_fail_attempts() {
  sed -nE \
   -e 's/.*Failed [a-z/-]+ for (invalid user )?([^ ]*) from ([0-9a-fA-F:.]+) port ([0-9]+).*/F \3 \4 \2/p' \
   -e 's/.*Invalid user ([^ ]*) from ([0-9a-fA-F:.]+) port ([0-9]+).*/C \2 \3 \1/p' \
   -e 's/.*(Connection closed by|Disconnected from) (invalid|authenticating) user
        ([^ ]*) ([0-9a-fA-F:.]+) port ([0-9]+).*\[preauth\].*/C \4 \5 \3/p' |
  awk '$1 == "F" { print $2, $4; failed[$2 " " $3] = 1; next }
       { k = $2 " " $3; if (!(k in ip)) { ip[k] = $2; usr[k] = $4 } }
       END { for (k in ip) if (!(k in failed)) print ip[k], usr[k] }'
}
```

Kết nối có dòng `Failed ...` được đếm theo số dòng Failed; kết nối chỉ có `Invalid user`/`[preauth]` được đếm là một lần. Đầu ra là mỗi lần thử một dòng *IP user*, sau đó `sort | uniq -c` ra số lần theo IP.

4.4.3 Danh sách tin cậy theo dải mạng

`IDS_WHITELIST` nhận cả IP lẻ và dải IPv4 dạng CIDR. So khớp bằng số học bit của Bash:

```
ipn=$(( (o1 << 24) | (o2 << 16) | (o3 << 8) | o4 ))
mask=$(( (0xFFFFFFFF << (32 - bits)) & 0xFFFFFFFF ))
(( (ipn & mask) == (netn & mask) )) && return 0     # IP thuộc dải mạng
```

4.4.4 Cảnh báo và chặn IP

Mỗi dấu hiệu có một khoá (ví dụ `ssh-brute:203.0.113.9`); dấu hiệu chỉ được báo lại sau `ALERT_COOLDOWN_MIN` phút. Các dấu hiệu mới được gom vào **một tin [TẤN CÔNG]** kèm gợi ý xử lý. Khi `AUTO_BAN=yes`, IP dò mật khẩu bị chặn bằng `ufw` (nếu đang bật) hoặc `iptables`, và được ghi vào danh sách để `alert banned`/`unban` quản lý.

CHÈN ẢNH: `hinh/23-alert-security.png`

Laptop 1: `sudo sysadmin alert security` ngay sau khi
Laptop 2 dò mật khẩu (bước 8.4–8.6 trong kịch bản demo).

Hình 4.9: IDS phát hiện dò mật khẩu, dò tên tài khoản, đăng nhập sau khi dò và tự chặn IP

CHÈN ẢNH:
`hinh/24-telegram-tan-cong.png`

Chụp màn hình điện thoại sau bước trên.

Hình 4.10: Tin [TẤN CÔNG] trên điện thoại

4.5 Chức năng 4 — backup: sao lưu tài sản số

Mặc định sao lưu `/srv/technova`, `/home` và `/etc`. Một lần sao lưu: khoá `flock` chống chạy trùng → nén `tar -czp` → kiểm tra `gzip -t` → checksum SHA-256 → xoay vòng giữ 7 bản → **tải bản sao và checksum lên Google Drive**, xoá bản trên Drive cũ hơn 30 ngày → ghi lịch sử, cảnh báo nếu lỗi.

```
exec 9>"$dest/.backup.lock"
flock -n 9 || die "Đang có một tiến trình sao lưu khác chạy."
tar -czpf "$file" --ignore-failed-read "${excl[@]}" -C / "${rel[@]}"
gzip -t "$file" && (cd "$dest" && sha256sum "$name" > "$name.sha256")
cloud_upload "$file" "$file.sha256" backups     # rclone copy --retries 3
```

Trên Drive, cấu trúc thư mục là `TechNova-Server/<tên máy>/backups/` và `.../logs/`.

CHÈN ẢNH: `hinh/15-backup-run.png`

Laptop 1: `sudo sysadmin backup run`.

Hình 4.11: Sao lưu, kiểm tra toàn vẹn và tải lên Google Drive

CHÈN ẢNH: `hinh/16-drive-backups.png`

Mở Google Drive (điện thoại hoặc trình duyệt) vào `TechNova-Server/technova-core-srv/backups`.

Hình 4.12: Các bản sao lưu của nhiều đêm trên Google Drive

4.6 Chức năng 5 — scheduler: tự động hoá bảo dưỡng

Toolkit hỗ trợ hai cách lập lịch tương đương. `scheduler install` ghi một **khối lịch riêng** vào crontab của root (giữa hai dòng đánh dấu `>>> sysadmin-toolkit >>>`), cài lại hay gỡ không ảnh hưởng job khác. `scheduler timers-install` tạo **4 cặp systemd service + timer** — đây là phần "tạo service riêng" của đề tài 4:

Bảng 4.1: Lịch tự động mặc định

systemd timer	Thời điểm	Tác vụ
`toolkit-monitor`	mỗi 5 phút	`alert check`: tài nguyên + IDS + cảnh báo
`toolkit-backup`	02:00 hằng ngày	`backup run` rồi `monitor log-upload`
`toolkit-maintenance`	03:30 hằng ngày	dọn `/tmp`, journald cũ, cache gói, core dump
`toolkit-report`	07:00 thứ Hai	`monitor report`

```
# /etc/systemd/system/toolkit-backup.service
[Service]
Type=oneshot
ExecStart=-/opt/sysadmin-toolkit/sysadmin.sh --no-color --yes backup run
ExecStart=/opt/sysadmin-toolkit/sysadmin.sh --no-color --yes monitor log-upload
Nice=15
IOSchedulingClass=idle

# /etc/systemd/system/toolkit-backup.timer
[Timer]
OnCalendar=*-*-* 02:00:00
RandomizedDelaySec=10min
Persistent=true
```

Dấu - trước lệnh sao lưu nghĩa là: nếu sao lưu lỗi (đã tự gửi cảnh báo) thì vẫn tiếp tục đóng gói log.

CHÈN ẢNH: `hinh/02-list-timers.png`

Trên máy chủ: `systemctl list-timers 'toolkit-*'`. Cột LAST phải có giá trị.

Hình 4.13: Bốn systemd timer của toolkit đã chạy nhiều lần

4.7 Triển khai một lệnh: `install.sh --server`

`install.sh --server` cài gói phụ thuộc (gồm `openssh-server`, `iptables`, `rclone`), chép toolkit vào `/opt/sysadmin-toolkit` (chủ sở hữu root, vì timer chạy bằng root), rồi hỏi cấu hình:

Bảng 4.2: Các câu hỏi của `install.sh --server`

Câu hỏi	Tác dụng
Máy chuyên làm máy chủ?	Máy cá nhân thì không sao lưu cả `/home`
Thư mục cần sao lưu	`BACKUP_SOURCES`
IP / dải mạng tin cậy	Tự điền IP máy đang SSH vào (lấy từ `who -m`) và dải Tailscale nếu có
Tự chặn IP dò mật khẩu?	`AUTO_BAN`
Siết SSH?	`PermitRootLogin no`, `MaxAuthTries 4` trong `sshd_config.d/`, kiểm tra bằng `sshd -t` trước khi áp dụng
Laptop gập máy vẫn chạy?	`HandleLidSwitch=ignore` (chỉ hỏi khi máy có pin)
Lập lịch bằng timer hay cron	Cài 4 systemd timer hoặc khối cron

Cuối cùng toolkit chụp baseline cho IDS *sau* khi đã sửa cấu hình SSH, để không tự báo nhầm.

CHÈN ẢNH: `hinh/01-install-server.png`

Laptop 1 SSH vào máy chủ, chạy `sudo ./install.sh --server`. Chụp phần câu hỏi và dòng "Máy chủ đã sẵn sàng".

Hình 4.14: Triển khai toolkit lên máy Ubuntu thật bằng một lệnh

CHƯƠNG 5

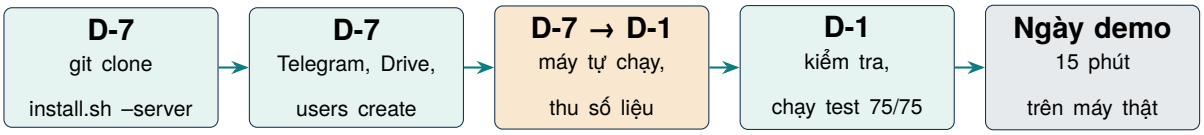
Triển khai thực tế và workflow demo

5.1 Môi trường triển khai

Bảng 5.1: Thiết bị triển khai

Thiết bị	Vai trò	Cấu hình
Máy Ubuntu thật	`technova-core-srv`	**[điền: Ubuntu 24.04, CPU, RAM, ổ đĩa]**
Laptop 1 (Kali)	Anh Hưng — quản trị từ xa	**[điền: IP, whitelist]**
Laptop 2	Nhân viên, kẻ tấn công	**[điền: IP, không whitelist]**
Điện thoại	Telegram, Google Drive	—
Mạng		**[điền: Wi-Fi LAN / Tailscale]**

5.2 Quy trình triển khai



Hình 5.1: Các mốc triển khai

1. Tải mã nguồn về máy chủ: `git clone https://github.com/duylmaoxd/technova-sysadmin-toolkit`.
2. Từ Laptop 1 SSH vào máy chủ, chạy `sudo ./install.sh --server` để toolkit tự whitelist IP của Laptop 1.
3. Nối Telegram (`alert setup-telegram`, `alert test`) và Google Drive (`rclone authorize "drive"` trên Laptop 1, `backup cloud-setup` trên máy chủ).
4. Tạo nhân viên và thư mục dự án (`users create`, `users setup-dirs`).
5. Để máy chạy liên tục **[điền: số ngày]** ngày; các thành viên thỉnh thoảng SSH vào làm việc.

CHÈN ẢNH:
`hinh/03-telegram-test.png`

Sau `sudo sysadmin alert test`, chụp màn hình điện thoại.

Hình 5.2: Tin thử từ toolkit tới Telegram

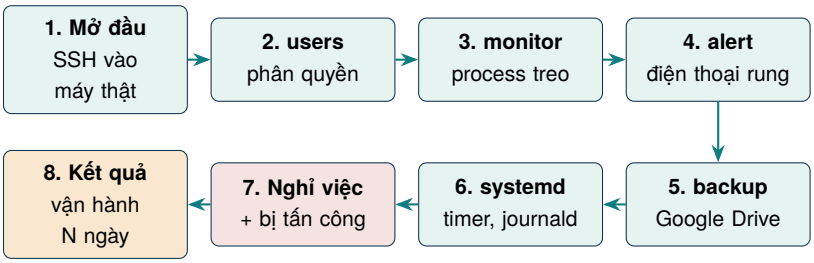
CHÈN ẢNH: `hinh/04-cloud-setup.png`

Trên máy chủ: `sudo sysadmin backup` `cloud-status` (thấy "remote gdrive sẵn sàng").

Hình 5.3: Kết nối Google Drive

5.3 Workflow demo

Buổi demo khoảng 15 phút, theo câu chuyện *"Một ngày làm việc từ xa của anh Hưng"*. Kịch bản chi tiết từng lệnh nằm trong tệp `docs/KICH-BAN-DEMO.md`.



Hình 5.4: Thứ tự các phần trong buổi demo

5.3.1 Bước 1 — Mở đầu: đây là máy chủ thật

Laptop 1 SSH vào máy chủ (đề tài 6), xem `hostnamectl; uptime` để cho thấy đây là máy Ubuntu thật đã chạy nhiều ngày.

CHÈN ẢNH: `hinh/05-ssh-tu-xa.png`

Laptop 1: `ssh hungnv@<IP máy chủ>` rồi `hostnamectl; uptime`.

Hình 5.5: Quản trị máy chủ từ máy khác qua SSH

5.3.2 Bước 2 — users: nhân viên làm việc và phân quyền

Laptop 2 đăng nhập bằng `cuonglv` (phòng data), thử vào thư mục phòng dev và bị từ chối; tạo tệp trong `data/` và tệp tự thuộc nhóm `data` nhờ SGID (Hình 4.3). Laptop 1 chạy `users audit` (Hình 4.4).

5.3.3 Bước 3 — monitor: có người treo process

Laptop 2 chạy một tiến trình ngốn CPU đặt tên `train_model.py`. Laptop 1 dùng `monitor who`, `usage`, `hogs` để tìm ra người và tiến trình (Hình 4.5, 4.6), rồi `monitor renice` hạ ưu tiên về 19 (đề tài 1).

5.3.4 Bước 4 — alert: cảnh báo tới điện thoại

`alert check` phát hiện tiến trình ngốn tài nguyên, điện thoại nhận tin (Hình 4.7, 4.8). Sau khi `monitor kill`, lần kiểm tra kế tiếp gửi tin "đã ổn định".

CHÈN ẢNH:
`hinh/14-telegram-on-dinh.png`

Sau `monitor kill` và `alert check`, chụp màn hình điện thoại.

Hình 5.6: Tin "ĐÃ ỔN ĐỊNH" sau khi xử lý sự cố

5.3.5 Bước 5 — backup: sao lưu lên Google Drive

`backup run` tạo bản sao và tải lên Drive; mở Drive trên điện thoại thấy bản vừa tạo cùng các bản của những đêm trước (Hình 4.11, 4.12). Khôi phục thử và kiểm tra nội dung.

CHÈN ẢNH: `hinh/17-backup-restore.png`

Laptop 1: `sudo sysadmin backup verify <file>` rồi `sudo sysadmin --yes backup restore <file> /tmp/restore && cat /tmp/restore/srv/technova/data/model.txt`.

Hình 5.7: Kiểm tra toàn vẹn và khôi phục đúng nội dung

5.3.6 Bước 6 — scheduler và systemd: máy chủ tự vận hành

CHÈN ẢNH: `hinh/18-systemctl-cat.png`

Laptop 1: `systemctl cat toolkit-backup.service toolkit-backup.timer`.

Hình 5.8: Service do toolkit tạo

CHÈN ẢNH: `hinh/19-journalctl-backup.png`

Laptop 1: `journalctl -u toolkit-backup --since "3 days ago" | tail -20`.

Hình 5.9: Nhật ký các đêm sao lưu trong journald

5.3.7 Bước 7 — nhân viên nghỉ việc, rồi máy chủ bị tấn công

Nghỉ việc: Laptop 2 đang SSH bằng `binhtt`; Laptop 1 chạy `users offboard binhtt`, phiên trên Laptop 2 bị ngắt ngay và không đăng nhập lại được.

CHÈN ẢNH: `hinh/20-offboard.png`

Laptop 1: `sudo sysadmin users offboard binhtt`.

Hình 5.10: Quy trình nghỉ việc 5 bước

CHÈN ẢNH: `hinh/21-laptop2-bi-ngat.png`

Màn hình Laptop 2: phiên `binhtt` bị đóng, lần `ssh binhtt@<IP>` sau đó thất bại.

Hình 5.11: Phiên của nhân viên nghỉ việc bị ngắt và không vào lại được

Bị tấn công: Laptop 2 thử đăng nhập bằng các tên tài khoản phổ biến với mật khẩu đoán bừa, rồi đăng nhập đúng bằng một tài khoản nhân viên. Laptop 1 chạy `alert security`: IDS báo dò mật khẩu, dò tên tài khoản, **nghi bị chiếm tài khoản**, tự chặn IP của Laptop 2 và gửi tin [TẤN CÔNG] (Hình 4.9, 4.10).

CHÈN ẢNH: `hinh/22-ssh-do-mat-khau.png`

Màn hình Laptop 2 khi chạy vòng lặp `ssh` ở bước 8.4 trong kịch bản demo (các lần "Permission denied").

Hình 5.12: Laptop 2 thử đăng nhập bằng nhiều tài khoản với mật khẩu sai

CHÈN ẢNH: `hinh/25-ssh-bi-chan.png`

Laptop 2: `ssh cuonglv@<IP>` bị treo rồi hết thời gian chờ.

Hình 5.13: Kết nối từ Laptop 2 bị tường lửa chặn

CHÈN ẢNH: `hinh/26-alert-banned.png`

Laptop 1: `sudo sysadmin alert banned` và `sudo iptables -S INPUT | grep toolkit`.

Hình 5.14: Danh sách IP bị chặn và luật iptables tương ứng

CHÈN ẢNH: `hinh/27-logcheck.png`

Laptop 1: `sudo sysadmin monitor logcheck 1`. Chụp mục "Đăng nhập SSH thất bại" và "thành công".

Hình 5.15: Báo cáo nhật ký 1 giờ qua

5.3.8 Bước 8 — kết quả vận hành thực tế

Trình bày số liệu tích luỹ sau những ngày máy chủ tự chạy (mục 6.3).

CHÈN ẢNH: `hinh/28-alert-history.png`

Laptop 1: `sudo sysadmin alert history`.

Hình 5.16: Lịch sử cảnh báo trong thời gian vận hành

CHÈN ẢNH: `hinh/29-report-html.png`

`sudo sysadmin monitor report`, mở tệp HTML trong `reports/` bằng trình duyệt.

Hình 5.17: Báo cáo HTML với biểu đồ CPU/RAM/Disk nhiều ngày

CHÈN ẢNH: `hinh/30-drive-logs.png`

Google Drive:

`TechNova-Server/technova-core-srv/logs`.

Hình 5.18: Các gói log hằng đêm trên Google Drive

CHƯƠNG 6

Kiểm thử và đánh giá

6.1 Môi trường kiểm thử

- **Kiểm thử tự động**: container Ubuntu 24.04 (hostname `technova-core-srv`, root, `CAP_SYS_NICE`, `CAP_NET_ADMIN`).
- **Kiểm thử đường triển khai thật**: container Ubuntu 24.04 **có systemd làm PID 1** (journald, `ssh.service`). `install.sh --server` chạy trọn vẹn; 4 timer tự kích hoạt đúng lịch; IDS đọc journald, bắt dò mật khẩu cả kiểu có mật khẩu lẫn kiểu chỉ-key và tự chặn IP bằng iptables.
- **Kiểm thử kênh cảnh báo**: máy chủ Telegram API và SMTP giả lập nhận đúng tin [TẤN CÔNG] liệt kê đủ các dấu hiệu.
- **Máy chủ thật**: **[điền: máy, thời gian vận hành]** .
- Kiểm tra tĩnh bằng **shellcheck**: không còn cảnh báo.

6.2 Kịch bản kiểm thử tự động

Script `tests/demo-test.sh` mô phỏng trọn "một ngày của anh Hưng" và kiểm chứng từng bước bằng điều kiện cụ thể trên hệ thống (thành viên nhóm, quyền thư mục, tiến trình còn sống, nội dung crontab, luật iptables, tệp trên "Drive" giả lập…). Phần Google Drive dùng remote rclone kiểu local nên không gửi dữ liệu ra Internet.

Bảng 6.1: Kết quả kiểm thử tự động

Nhóm	Nội dung kiểm chứng	Số test	Kết quả
Nền tảng	Phiên bản, help tự sinh, từ chối tham số sai, dry-run	5	5/5
users	7 nhân viên, phòng ban, sudo, ép đổi mật khẩu, quyền 2770/1777, SGID, sticky, lock/unlock, audit	18	18/18
monitor	Process treo, usage, hogs, top, who/overview/troubleshoot, renice	6	6/6
alert	Phát hiện sự cố, log, cooldown, kill, "đã ổn định", metrics, đổi ngưỡng	7	7/7
IDS	Baseline, không báo nhầm, dò mật khẩu, **dò khi chỉ dùng key**, dò tên tài khoản, chiếm tài khoản, tệp bị sửa, UID 0, process từ /tmp, gửi cảnh báo, chống spam, **whitelist CIDR**, logcheck, ban/banned/unban	16	16/16
backup	Bản sao, SHA-256, dữ liệu dự án, verify, khôi phục, xoay vòng, Drive, backup + log lên Drive, cloud-list	10	10/10
scheduler	Khối cron đủ 5 job, job tuỳ chỉnh, explain, từ chối cron sai, bảo dưỡng, gỡ lịch	7	7/7
Nghỉ việc	kick, offboard, lưu trữ home, từ chối offboard root	4	4/4
Dọn dẹp	Xoá nhân viên, thư mục, nhóm demo	2	2/2
Tổng		**75**	**75/75**

CHÈN ẢNH: `hinh/31-test-75-pass.png`

Laptop 1, thư mục mã nguồn: `docker run --rm --cap-add SYS_NICE --cap-add NET_ADMIN -v "$PWD/tests:/tests:ro" technova/sysadmin-toolkit:1.0 bash /tests/demo-test.sh --yes`. Chụp dòng "KẾT QUẢ: 75/75 PASS".

Hình 6.1: Kết quả chạy bộ kiểm thử tự động

6.3 Kết quả vận hành thực tế

Bảng 6.2: Số liệu sau thời gian máy chủ tự vận hành

Chỉ số	Giá trị
Thời gian vận hành liên tục	**[điền: số ngày, từ ngày … đến ngày …]**
Số lần `alert check` đã chạy (timer 5 phút)	**[điền: journalctl -u toolkit-monitor | grep -c ...]**
Số bản sao lưu đã tải lên Google Drive	**[điền: backup cloud-list]**
Số gói log đã tải lên Google Drive	**[điền: backup cloud-list]**
Số cảnh báo đã gửi (Telegram/email)	**[điền: alert history]**
Số lần đăng nhập SSH thất bại ghi nhận	**[điền: monitor logcheck 168]**
Số IP bị chặn	**[điền: alert banned]**
Sự cố thật phát hiện được (nếu có)	**[điền: mô tả]**

6.4 Đánh giá lợi ích của tự động hoá

Bảng 6.3: So sánh thao tác thủ công và dùng toolkit (ước tính của nhóm)

Công việc	Làm tay	Với toolkit
Tạo 7 nhân viên + phòng ban + thư mục	$\approx$ 50 lệnh, 20–30 phút, dễ sai quyền	2 lệnh, $<$ 10 giây, có kiểm chứng
Tìm ai đang treo process	`ps/top`, tự đối chiếu user	`monitor hogs`: một lệnh
Phát hiện sự cố lúc 2 giờ sáng	Chỉ biết khi nhân viên phản ánh	Cảnh báo trong $\leq$ 5 phút
Phát hiện dò mật khẩu SSH	Đọc `auth.log` bằng tay, thường không ai đọc	Tự phát hiện, tự chặn, báo về điện thoại
Sao lưu hằng ngày ra ngoài máy	Dễ quên, không kiểm tra, để chung máy	Tự động, checksum, xoay vòng, lên Drive
Nhân viên nghỉ việc	Dễ sót bước (sudo, crontab, phiên còn mở)	`users offboard`: 5 bước một lần

6.5 Hạn chế

- Chỉ quản lý một máy chủ; chưa có quản lý tập trung nhiều máy.

- IDS dựa trên luật và ngưỡng cố định: không phát hiện được kiểu tấn công chưa có luật, và có thể báo nhầm khi ngưỡng không phù hợp với từng máy.
- Whitelist theo dải mạng mới hỗ trợ IPv4.
- Gửi email phụ thuộc cấu hình SMTP bên ngoài; Google Drive phụ thuộc token OAuth (cần cấp lại khi hết hạn).

CHƯƠNG 7

Kết luận và hướng phát triển

7.1 Kết luận

Đồ án đã xây dựng và **triển khai thực tế** LinuxAdmin Toolkit, chứng minh Bash scripting đủ sức tự động hoá công việc quản trị hằng ngày của một máy chủ doanh nghiệp: quản lý vòng đời nhân viên, phân quyền theo phòng ban, giám sát và xử lý tiến trình gây sự cố, kiểm tra nhật ký, phát hiện xâm nhập, cảnh báo tức thời, sao lưu ra đám mây và bảo dưỡng định kỳ bằng systemd. Thiết kế "giao diện là lớp vỏ của CLI" giúp toolkit vừa thân thiện qua SSH vừa dùng được trong script, cron và systemd. Bộ kiểm thử tự động 75 bước xác nhận các chức năng hoạt động đúng.

7.2 Hướng phát triển

- **Phát hiện bất thường bằng thống kê**: học thói quen đăng nhập của từng nhân viên (giờ, IP) và báo khi lệch; so mức CPU/RAM với trung bình theo từng giờ trong ngày (độ lệch chuẩn) từ `metrics.csv`.
- Quản lý nhiều máy chủ qua SSH hoặc chuyển sang Ansible.
- Mã hoá bản sao lưu bằng GPG trước khi tải lên đám mây.
- Dashboard web đọc `metrics.csv` và lịch sử cảnh báo; theo dõi lệnh sudo bằng `auditd`.

PHỤ LỤC A

Hướng dẫn sử dụng

A.1 Cài đặt trên máy Ubuntu thật

```
sudo apt update && sudo apt install -y git
git clone https://github.com/duylmaoxd/technova-sysadmin-toolkit.git
cd technova-sysadmin-toolkit
sudo ./install.sh --server            # cài + hỏi cấu hình + bật timer + baseline IDS
sudo sysadmin alert setup-telegram    # nhận cảnh báo trên điện thoại
sudo sysadmin alert test
sudo sysadmin backup cloud-setup      # trước đó: rclone authorize "drive" trên máy có trình d
sudo sysadmin users create && sudo sysadmin users setup-dirs
```

Từ máy khác: `ssh hungnv@<IP máy chủ>` rồi `sudo sysadmin --tui` hoặc gõ lệnh trực tiếp. Gỡ cài đặt: `sudo ./install.sh --uninstall` (bản sao lưu được giữ lại).

A.2 Các lệnh thường dùng

Bảng A.1: Tra cứu nhanh theo tình huống

Tình huống	Lệnh
Có nhân viên mới (sửa `users.csv` trước)	`sudo sysadmin users create`
Nhân viên nghỉ việc	`sudo sysadmin users offboard <user>`
Ai đang đăng nhập, ai ngốn CPU/RAM	`sysadmin monitor who · usage · hogs`
Hạ ưu tiên / dừng tiến trình	`sudo sysadmin monitor renice <PID> · kill <PID>`
Log 24 giờ qua có gì bất thường	`sudo sysadmin monitor logcheck`
Máy có bị tấn công không	`sudo sysadmin alert security`
Chặn / bỏ chặn IP	`sudo sysadmin alert ban <IP> · unban <IP> · banned`
Đã sửa cấu hình hợp lệ, IDS báo tệp bị đổi	`sudo sysadmin alert baseline`
Sao lưu ngay / kiểm tra / khôi phục	`sudo sysadmin backup run · verify <file> · restore <file> <thư mục>`
Xem bản sao trên Google Drive	`sudo sysadmin backup cloud-list`
Xem lịch tự động	`systemctl list-timers 'toolkit-*'`
Hiểu một biểu thức cron	`sysadmin scheduler explain "30 3 * * *"`

A.3 Tham số cấu hình chính

Tệp `/opt/sysadmin-toolkit/config/toolkit.conf`:

Bảng A.2: Tham số cấu hình chính

Biến	Mặc định	Ý nghĩa
`CPU/MEM/DISK_THRESHOLD`	80 / 85 / 90	Ngưỡng cảnh báo (%)
`HOG_CPU` / `HOG_MEM`	90 / 30	Ngưỡng coi là process treo (%)
`IDS_WINDOW_MIN`	10	Cửa sổ đọc log của IDS (phút)
`IDS_SSH_FAIL_PER_IP`	5	Số lần thử từ một IP coi là dò mật khẩu
`IDS_SPRAY_USERS`	5	Số username lạ coi là dò tên tài khoản
`AUTO_BAN`	no	`yes`: tự chặn IP dò mật khẩu
`IDS_WHITELIST`	`127.0.0.1 ::1`	IP / dải mạng không bao giờ bị chặn
`ALERT_COOLDOWN_MIN`	30	Mỗi dấu hiệu chỉ báo lại sau ngần này phút
`BACKUP_SOURCES`	`/etc /home /srv/technova`	Thư mục sao lưu
`BACKUP_KEEP`	7	Số bản giữ tại máy
`GDRIVE_REMOTE` / `GDRIVE_KEEP_DAYS`	— / 30	Thư mục Drive / số ngày giữ trên Drive

PHỤ LỤC B

Danh sách lệnh

Chức năng	Action
users	list, create, delete, add, remove, lock, unlock, passwd, sudo, policy, set-policy, audit, perm, shared-dir, setup-dirs, kick, offboard, demo, demo-clean
monitor	who, usage, top, hogs, renice, kill, overview, memory, disk, logs, logcheck, log-upload, auth, troubleshoot, report, watch, history
alert	check, security, baseline, ban, unban, banned, status, test, setup-mail, setup-telegram, set-threshold, stress, history
backup	run, list, verify, restore, rotate, history, cloud-setup, cloud-status, upload, cloud-list
scheduler	list, install, maintenance, remove, add, explain, at, at-list, at-remove, log, timers-install, timers-remove

Tuỳ chọn chung: `--tui`, `--cli`, `--dry-run`, `--yes`, `--ascii`, `--no-color`, `--config`. Xem chi tiết: `sysadmin help <chức năng>`. Mã nguồn: `https://github.com/duylmaoxd/technova-sysadmin-tool`